



FUNDAMENTOS DE SEGURANÇA DA INFORMAÇÃO

Jeanine dos Santos
Barreto

Assinatura digital

Objetivos de aprendizagem

Ao final deste texto, você deve apresentar os seguintes aprendizados:

- Compreender o que é uma assinatura digital.
- Identificar os tipos de chaves criptográficas.
- Reconhecer a cadeia hierárquica de confiança que viabiliza a emissão de assinaturas digitais.

Introdução

As pessoas e as empresas passaram a utilizar a Internet para trocar todo tipo de informações, inclusive financeiras, mas o fato é que a rede mundial não oferece a segurança necessária para que as operações virtuais sejam feitas com tranquilidade.

Nesse sentido, a assinatura digital é uma forma de autenticar informações digitais contidas em documentos eletrônicos, garantindo que o indivíduo que está assinando virtualmente o documento, é quem ele realmente diz ser.

Neste capítulo, você vai estudar o conceito de assinatura digital, os tipos de chaves criptográficas e conhecer a cadeia hierárquica de confiança que viabiliza a emissão de assinaturas digitais.

O que é assinatura digital

Com a expansão da informática, tanto para pessoas físicas quanto para empresas, grande parte dos arquivos e documentos transita ou pela Internet, ou por outro meio digital. As empresas passaram a utilizar a Internet para efetivar seus negócios, visando maior agilidade em seus processos e aumento dos lucros obtidos. As pessoas passaram a executar virtualmente as atividades que desempenhavam apenas fisicamente, incluindo assinatura de contratos, declaração de imposto de renda e pagamento de faturas. Apesar da facilidade oferecida pela Internet, a privacidade, o sigilo e a segurança ficaram ameaçados.

Em vista disso, a assinatura digital configura uma forma de conferir segurança, autenticidade e integridade para os documentos eletrônicos. Ela surgiu como uma maneira de provar a veracidade das informações contidas nos documentos digitais, em substituição às assinaturas convencionais que validam documentos em papel. O termo assinatura não foi escolhido em vão: a intenção é remeter à assinatura feita à mão em documentos confeccionados em papel.



Fique atento

Uma assinatura digital não é a mesma coisa que uma assinatura eletrônica. A assinatura eletrônica envolve qualquer forma de identificação do remetente de uma mensagem emitida digitalmente, sem que haja necessidade de regulamentação ou meios para tornar a assinatura confiável. Como exemplo, pode-se citar a identificação do remetente de uma mensagem de correio eletrônico.

Uma assinatura digital é uma técnica ou ferramenta aceita pelo governo, pelo judiciário e pelas empresas, que possibilita que um usuário faça a reprodução de sua assinatura em documentos digitais, sem que a necessidade de utilizar papel na operação. A utilização da assinatura digital, principalmente pelas empresas, traz uma grande economia no volume de papel gasto, além de economizar espaço de armazenamento e em despesas com correio.

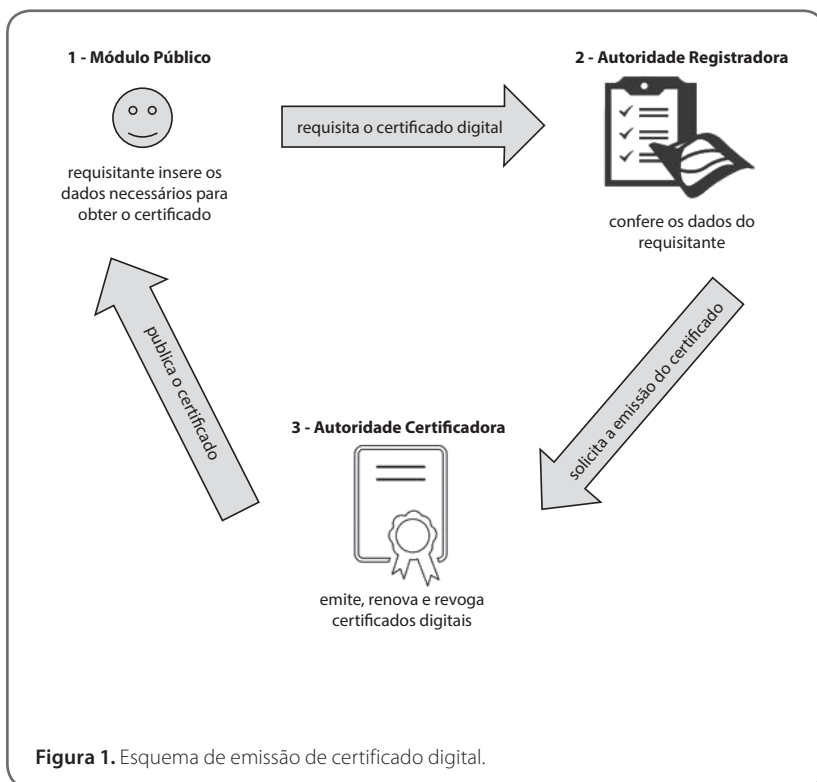
A assinatura digital é uma ferramenta extremamente segura, pois utiliza criptografia e vincula, em todos os documentos assinados, um certificado digital que é obtido previamente e que serve para comprovar a sua autenticidade. Em outras palavras, a assinatura convencional do titular é substituída por uma assinatura digital, que vem com um certificado e uma chave privada exclusiva do titular, o que lhe confere veracidade. Esse certificado é assinado por uma das inúmeras autoridades certificadoras, entidades credenciadas em que todos confiam. Para obter uma assinatura digital, é preciso fazer a solicitação para uma das Autoridades Certificadoras.

Foi a partir de 2001, com a criação da Infraestrutura de Chaves Públicas Brasileiras (ICP-Brasil) que os documentos digitais puderam ser assinados digitalmente, substituindo totalmente o uso do papel, e com validade, inclusive jurídica, em todo o Brasil (BRASIL, 2018). A ICP-Brasil configura um sistema de serviços, políticas e recursos que dá suporte para a utilização de criptografia

de chave pública, possibilitando fazer a autenticação das partes envolvidas em uma transação digital. Ela fornece as ferramentas necessárias para gerenciar os certificados digitais e as chaves públicas, formando uma cadeia hierárquica de confiança que viabiliza a emissão dos certificados digitais para a identificação virtual de alguém que está assinando um documento virtualmente.

A ICP-Brasil é responsável pela regulamentação das práticas e dos procedimentos de emissão de certificados digitais, além de outros serviços digitais associados a eles. Um processo normal de emissão de certificado digital (Figura 1), ou seja, que possibilita a veracidade da assinatura digital, envolve os seguintes elementos (BALDAM, 2016):

- **Módulo Público** — é um portal de serviços, onde o usuário final solicita o certificado digital ou faz a instalação do certificado digital. Por meio do módulo público é possível também acompanhar, pela interface de status do processo, como está o andamento da emissão do certificado digital.
- **Autoridade certificadora (AC)** — é a entidade responsável por emitir, gerar, renovar e revogar os certificados digitais. Também é responsável por distribuir as chaves públicas, emitir a Lista de Certificados Revogados (LCR) e manter as regras de publicação dos certificados digitais. Uma autoridade certificadora pode ser uma empresa, uma organização, um indivíduo público, ou privado. É essa entidade que recebe a requisição do certificado digital (assinada pela autoridade de registro), confere a assinatura digital da autoridade de registro e faz a emissão do certificado digital que será conferido ao usuário final. A forma de funcionamento de uma AC vai determinar quais os tipos de certificado digital que ela é capaz de emitir, e essa informação está descrita em um documento chamado Declaração de Práticas de Certificação (DPC).
- **Autoridade de registro (AR)** — é a entidade que estabelece uma interface entre uma AC e o usuário. É a autoridade de registro que confere as informações do usuário e faz o envio da requisição do certificado para a AC. Essa autoridade é muito importante, já que o nível de confiança atribuído ao certificado está diretamente ligado à qualidade do processo de conferência dessas informações. Uma AC necessariamente vai confiar nas informações passadas por uma AR, e o certificado vai ser emitido sem a necessidade de nenhum outro tipo de verificação nas informações. Por isso a confiança é necessária, a fim de garantir a confiabilidade durante todo o processo.



A assinatura digital permite que um documento digital tenha a mesma validade, inclusive jurídica, de um documento assinado em cartório, por exemplo. A assinatura digital é utilizada para validar muitos documentos e operações que são feitas virtualmente, como a entrega da declaração de imposto de renda e a assinatura de contratos. Uma assinatura digital prova com a máxima certeza que a mensagem recebida pelo destinatário teve origem no remetente que diz ter enviado. Para ser tão segura, uma assinatura digital precisa ter as seguintes características (NAKAMURA; GEUS, 2007):

- **Autenticidade** — o destinatário da mensagem pode confirmar com certeza que a assinatura foi emitida pelo remetente.
- **Integridade** — a certeza de que a mensagem trafegou sem nenhuma alteração do remetente até o destinatário, pois do contrário a assinatura não tem validade.
- **Irretratabilidade** — o remetente não pode negar que a mensagem é autêntica.

Uma assinatura digital é, atualmente, a maneira mais avançada, segura e confiável de fazer uma assinatura eletrônica e substituir a assinatura em papel. Desde que seja emitida pelas autoridades corretas, ela cumpre todas as exigências da legislação a respeito disso.

Tipos de chaves criptográficas

Existem dois tipos de chaves criptográficas para a assinatura digital: a criptografia simétrica e a assimétrica.



Fique atento

A criptografia envolve a aplicação de um algoritmo de codificação em dados que precisam ficar incompreensíveis e ininteligíveis para pessoas que não estão participando de uma transação específica.

Já a descryptografia consiste na aplicação de um algoritmo para tornar a mensagem legível novamente, por um indivíduo que saiba como descryptografar os dados.

Criptografia simétrica

A criptografia simétrica tem fundamento em algoritmos que dependem de uma chave única, que é chamada de chave secreta e utilizada no processo de codificação e decodificação da mensagem, como exposto na Figura 2. Para assegurar a integridade da mensagem transmitida é fundamental que somente o remetente e o destinatário da mensagem conheçam a chave. A criptografia simétrica utiliza a mesma chave para criptografar e descryptografar os dados, logo, o algoritmo utilizado por ela é mais simples e o processo de criptografia é bem mais rápido (SILVEIRA, 2006).

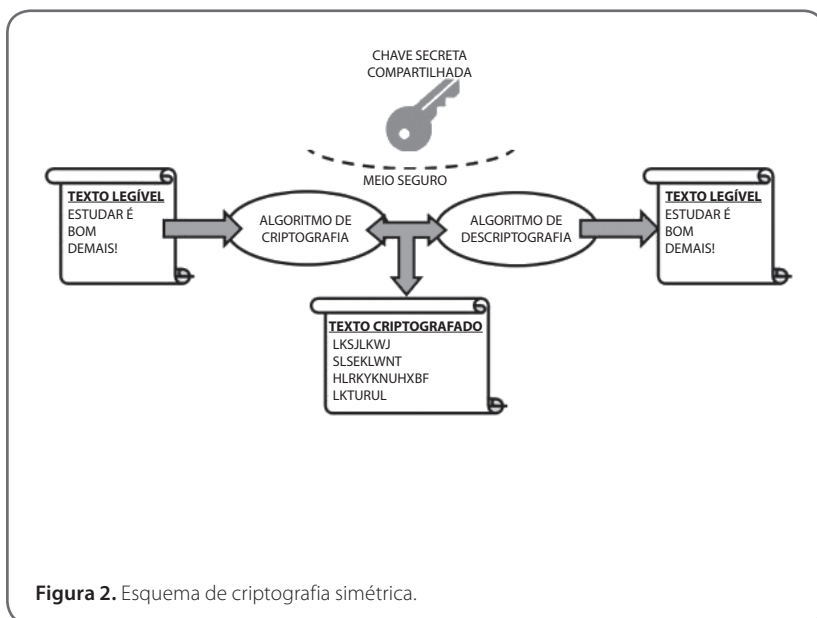


Figura 2. Esquema de criptografia simétrica.

A operação de um algoritmo de chave simétrica é mais simples porque existe apenas uma chave envolvida na comunicação. Essa chave representa um segredo que é compartilhado entre todos os envolvidos para que um canal de comunicação minimamente confidencial possa ser estabelecido e mantido, ou seja, esse tipo de criptografia exige que seja utilizado um canal protegido para que a troca de chave seja feita, o que torna esse tipo de criptografia menos utilizado.

O princípio básico da criptografia simétrica é que apenas uma chave é usada pelos envolvidos na troca de mensagens e ela é conhecida apenas por eles. Isso, porém, é praticamente impossível de ser assegurado, já que existe uma facilidade muito grande de ataque e interceptação da troca de mensagens. Esse é o maior problema da criptografia simétrica: a obrigatoriedade do compartilhamento da chave secreta com todos os indivíduos que precisam ler e entender a mensagem, o que possibilita a alteração de partes da mensagem por qualquer um deles.

Outro incômodo com a utilização da criptografia simétrica diz respeito aos gastos com o uso de canais seguros e com a distribuição de chaves, o que torna possível sua utilização somente por quem pode pagar por isso, como governos e grandes instituições bancárias. O gerenciamento da chave secreta também é uma dificuldade do uso desse tipo de criptografia, pois é uma atividade que envolve escolher, distribuir e armazenar as chaves sem erro e sem perda, de

uma maneira que sejam alteradas com frequência e mantidas da forma mais segura possível durante a distribuição e a efetivação da transação.

Criptografia assimétrica

A criptografia assimétrica tem como fundamento a utilização de um par de chaves diferentes entre si, mas que mantêm um relacionamento matemático, o que permite que a mensagem criptografada por uma chave seja descriptografada somente pela outra chave do mesmo par (MARTINI, 2008). As duas chaves necessárias para a criptografia assimétrica são chamadas de chave pública e chave privada, e funcionam como mostrado na Figura 3. A chave pública pode ser de conhecimento do público em geral, mas a chave privada deve ser de conhecimento apenas do seu titular.

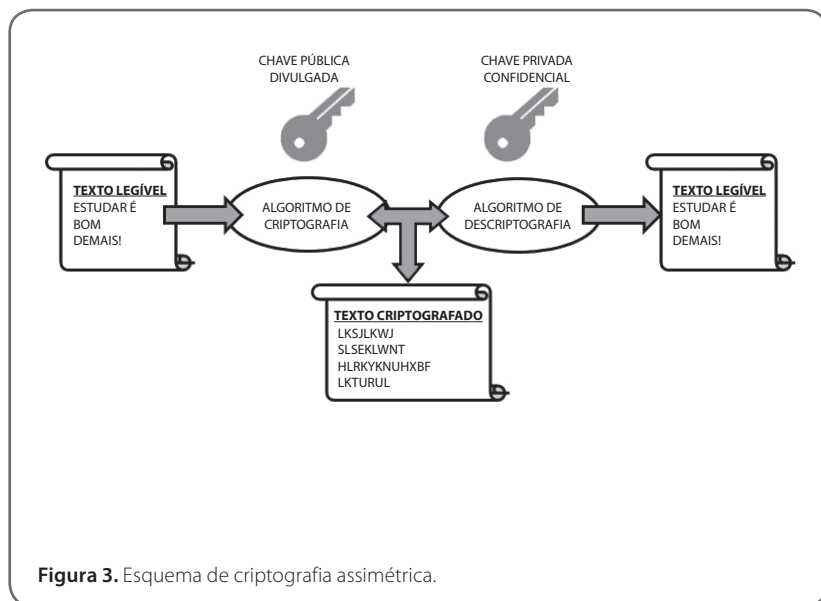


Figura 3. Esquema de criptografia assimétrica.

A obrigatoriedade de compartilhamento da chave secreta única e a utilização de apenas uma chave (características da criptografia simétrica) são resolvidas pela criptografia assimétrica, visto que ela utiliza duas chaves, uma para criptografar e outra para descriptografar. O algoritmo utilizado é mais complexo e por isso o processo de criptografia é mais lento, mas em compensação é bem mais seguro.

Nesse tipo de criptografia, somente uma das partes envolvidas na transação possui a chave privada, que é mantida em segredo e é praticamente impossível deduzi-la. A chave pública é disponibilizada para todas as outras partes envolvidas e, dessa forma, qualquer indivíduo pode criptografar dados. Por outro lado, as mensagens que forem criptografadas pela chave pública só poderão ser descriptografadas pela chave privada, o que oferece segurança e confiabilidade para a operação de comunicação.

A cadeia hierárquica de confiança

Apesar de a ideia das assinaturas digitais ser antiga, no Brasil ela foi implementada por meio da Medida Provisória nº. 2.200–2/2001, que instituiu a ICP-Brasil (BRASIL, 2001). O propósito da ICP-Brasil é explicado logo em seu artigo primeiro:

Art. 1º Fica instituída a Infra-Estrutura de Chaves Públicas Brasileira – ICP-Brasil, para garantir a autenticidade, a integridade e a validade jurídica de documentos em forma eletrônica, das aplicações de suporte e das aplicações habilitadas que utilizem certificados digitais, bem como a realização de transações eletrônicas seguras (BRASIL, 2001, documento on-line).

Essa medida provisória, que permanece em vigor, deixa claro que todos os documentos digitais com certificado emitido pela ICP-Brasil possuem validade em todos os segmentos, inclusive no jurídico. Entretanto, a Medida Provisória nº. 2.002–2/2001 também libera a comprovação de autenticidade por outros meios de comprovação de titularidade, mesmo os não emitidos pela ICP-Brasil, desde que ambas as partes envolvidas na transação aceitem esse outro meio como válido. Em outras palavras, a ICP-Brasil é a autoridade brasileira oficial que informa e gerencia as técnicas disponíveis para gerar documentos digitais válidos. Porém, ela não é a única, nada impede a existência de outras entidades e outros meios de validação de documentos. Ao longo do texto da Medida Provisória, fica estabelecido que a ICP-Brasil será formada tanto por ACs, quanto por ARs, ou seja, uma entidade não é mais importante ou principal do que a outra. As entidades são escolhidas pelos requisitantes de acordo com a funcionalidade requerida para o certificado digital em questão.

A ICP-Brasil é responsável pelo conjunto de regras e padrões que permitem a compatibilidade entre os vários tipos de certificados digitais existentes, fornecendo um nível de segurança compatível com os melhores padrões

disponíveis atualmente (MARTINI, 2008). Existe um rígido controle, feito por meio de auditoria, em todas as entidades que participam da ICP-Brasil. Esse controle é fundamental porque aumenta a confiabilidade depositada nos padrões seguidos. Atualmente, a ICP-Brasil é formada basicamente pelas seguintes entidades (BRASIL, 2018):

- **Autoridade certificadora (AC)** — essa entidade pode ser pública ou privada, e é subordinada hierarquicamente à ICP-Brasil. Seu papel é verificar se o titular do certificado tem a chave privada correspondente à chave pública que faz parte daquele certificado. A AC faz a criação e a assinatura digital do certificado do usuário. O certificado emitido pela AC representa a declaração de identidade do titular, que possui um par único de chaves pública e privada. Essa entidade também emite uma LCR e mantém os registros de suas operações.
- **Autoridade de registro (AR)** — essa entidade faz o intermédio entre o requisitante do certificado digital e a AC. Ela é vinculada a uma AC e tem como responsabilidade receber, validar e encaminhar as solicitações de emissão ou revogação de certificados digitais, além de identificar de forma presencial os requisitantes. Essa entidade também tem que manter um registro de todas as suas operações e pode estar localizada fisicamente em uma AC, ou ser uma entidade de registro que opera remotamente.
- **AC–Raiz** — a AC–Raiz é a primeira da cadeia de certificação. Sua atribuição é executar as políticas de certificados e as normas técnicas e operacionais que são aprovadas pelo comitê gestor da ICP-Brasil, além de verificar se as ACs estão atuando conforme as diretrizes e normas técnicas estabelecidas pelo comitê. Suas atividades envolvem a emissão, a expedição, a distribuição, a revogação e o gerenciamento dos certificados das ACs de nível imediatamente subsequente ao seu nível. Essa entidade também faz a emissão de uma LCR, e fiscaliza e audita ACs, ARs e demais prestadores de serviço que são habilitados pela ICP-Brasil.
- **Autoridade certificadora do tempo (ACT)** — essa entidade é responsável pelo fornecimento do Carimbo do Tempo, um conjunto de atributos fornecidos pela parte confiável do tempo, que confere prova de sua existência em determinado período, sendo associado a uma assinatura digital. Resumindo, quando um documento é produzido, seu conteúdo é criptografado e recebe atributos (ano, mês, dia, hora, minuto, segundo), e em seguida é atestado com uma assinatura, realizada por meio de

certificado digital que comprova sua autenticidade. A ACT atesta, então, a questão de tempo de uma transação e também o seu conteúdo.

- **Prestador de serviço de suporte (PSS)** — é a entidade que executa as atividades descritas na política do certificado e na DPC da AC à qual está vinculada diretamente, ou por intermédio da AR.
- **Prestador de serviço biométrico (PSBio)** — é a entidade que tem capacidade técnica para realizar a identificação biométrica, possibilitando um registro único nos bancos de dados e sistemas de dados biométricos de toda a ICP-Brasil. Ela realiza a verificação biométrica do requisitante de um certificado digital e faz a comparação da biometria, que tem característica única, de acordo com padrões internacionais de utilização.

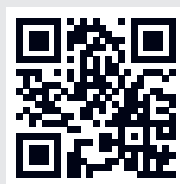
São muitas as ACs credenciadas pela ICP-Brasil, não sendo possível eleger uma mais importante, pois a escolha da AC pelo requisitante vai depender do tipo de certificado digital pretendido por ele. As ACs que se destacam como órgãos do governo ou grandes entidades são (BRASIL, 2018):

- **Serviço Federal de Processamento de Dados (Serpro)** — primeira AC credenciada pela ICP-Brasil.



Link

Para saber como se obtém um certificado digital através da Serpro, acesse o *link* ou código a seguir:



<https://goo.gl/z4gZjX>

- **Caixa Econômica Federal** — única instituição financeira brasileira credenciada como AC da ICP-Brasil.



Link

Para saber como se obter um certificado digital através da Caixa Econômica Federal, acesse o *link* ou código a seguir:



<https://goo.gl/wMwuKY>

- **Serasa Experian** — AC que pertence ao setor privado. Ela fornece a segurança dos certificados digitais para quase a totalidade dos grupos financeiros que participam do Sistema de Pagamentos Brasileiro.
- **Certisign** — AC que tem foco duplo no segmento da certificação digital pois, além de viabilizar o fornecimento de uma ferramenta tecnológica, ainda desenvolve soluções para utilização exclusiva com certificados digitais emitidos pela ICP-Brasil.
- **Casa da Moeda do Brasil** — essa AC é uma das mais antigas instituições públicas brasileiras. A Casa da Moeda modernizou sua estrutura produtiva e administrativa, habilitando-se a prestar atendimento ao mercado de segurança na era da tecnologia.



Referências

BALDAM, R. *Gerenciamento de conteúdo empresarial*. Rio de Janeiro: Elsevier, 2016.

BRASIL. Instituto Nacional de Tecnologia da Informação. *ICP-Brasil*. 2018. Disponível em: <<http://www.iti.gov.br/icp-brasil>>. Acesso em: 1 ago. 2018.

BRASIL. *Medida Provisória nº. 2.200-2, de 24 de agosto de 2001*. Institui a Infra-Estrutura de Chaves Públicas Brasileira - ICP-Brasil, transforma o Instituto Nacional de Tecnologia da Informação em autarquia, e dá outras providências. Brasília, DF, 2001. Disponível em: <http://www.planalto.gov.br/ccivil_03/mpv/antigas_2001/2200-2.htm>. Acesso em: 1 ago. 2018

MARTINI, R. S. *Tecnologia e cidadania digital: tecnologia, sociedade e segurança*. Rio de Janeiro: Brasport, 2008.

NAKAMURA, E. T.; GEUS, P. L. *Segurança de redes em ambientes cooperativos*. São Paulo: Novatec, 2007.

SILVEIRA, S. A. Criptografia assimétrica...você ainda vai precisar dela. *Revista Eletrônica A REDE*, São Paulo, nº. 10, p. 32-33, jan. 2006.

Encerra aqui o trecho do livro disponibilizado para esta Unidade de Aprendizagem. Na Biblioteca Virtual da Instituição, você encontra a obra na íntegra.

Conteúdo:



SOLUÇÕES
EDUCACIONAIS
INTEGRADAS



FUNDAMENTOS DE SEGURANÇA DA INFORMAÇÃO

Jeanine dos Santos
Barreto

Recursos de autenticação

Objetivos de aprendizagem

Ao final deste texto, você deve apresentar os seguintes aprendizados:

- Compreender o que são recursos de autenticação.
- Identificar o processo de controle de acesso.
- Reconhecer os principais recursos de autenticação.

Introdução

O controle de acesso envolve permitir ou negar o acesso dos sujeitos envolvidos a determinados objetos de um sistema. Essa restrição de acesso é responsável pela diminuição considerável de incidentes e falhas de segurança da informação, que ocorreriam caso qualquer indivíduo pudesse acessar um sistema e modificar seus dados.

O controle de acesso é formado por outros processos menores, e a autenticação é um deles. Atualmente existem muitos recursos que podem ser utilizados para fazer a autenticação de um usuário em um sistema informatizado.

Neste capítulo, você vai estudar o conceito de recursos de autenticação e o processo de controle de acesso. Você vai ainda identificar os principais tipos de recursos de autenticação.

Recursos de autenticação

O **controle de acesso** a sistemas informatizados é um dos melhores exemplos de utilização de **recursos de autenticação**. Nesse tipo de sistema, o acesso deve ser permitido somente a usuários autorizados, sendo que o acesso de indivíduos não autorizados deve ser detectado e imediatamente impedido.

Normalmente, os usuários de sistemas informatizados são identificados e autenticados por meio de um processo chamado **logon**. Esse tipo de processo é usado para permitir o acesso dos usuários aos dados, às informações e aos aplicativos de um sistema. É comum que o *logon* envolva a digitação, pelo

usuário, de uma identificação (ID) e de uma senha. São essas duas informações que informam ao computador quem é o usuário e provam que ele é quem realmente diz ser.

Para que o processo de *logon* seja considerado eficiente, conforme Brasil (2012), ele deve:

- deixar claro para o usuário que ele só terá acesso se for autorizado;
- evitar divulgar informações sobre o sistema que será acessado antes de o *logon* ter sido feito com sucesso;
- validar o *logon* somente quando todas as informações necessárias tiverem sido inseridas, evitando dizer qual foi o campo digitado incorretamente pelo usuário;
- estabelecer uma quantidade máxima de tentativas de *logon* sem sucesso;
- estabelecer um tempo que o usuário deverá aguardar para tentar um novo *logon*, após ter excedido as tentativas sem sucesso;
- limitar um tempo máximo para que o usuário tente efetuar uma tentativa de *logon*.

Todos os usuários autorizados a acessar um sistema precisam ter uma **identificação de usuário**, ou **ID**, seja ela uma palavra, um conjunto aleatório de caracteres, uma matrícula de funcionário, de aluno ou de professor, ou qualquer outro tipo de identificação. Se a empresa optar por fazer a identificação dos usuários por meio de uma palavra ou um conjunto de caracteres, é necessário cuidado redobrado, estabelecendo quantidades mínima e máxima de caracteres e mistura de letras, símbolos e números.

A ID do usuário deve ser única, ou seja, nenhum outro usuário pode ter uma identificação igual, cada um deve ter uma identificação própria, individual. O fato de a identificação ser única permite que a área de segurança da informação tenha um controle efetivo das ações praticadas pelos usuários, possuindo os dados necessários para uma possível auditoria.

Concluída a identificação do usuário, é necessário que seja feita a sua autenticação. A **autenticação** consiste no ato de confirmar se o usuário é quem realmente ele está dizendo ser, se ele é autêntico. A autenticação tem relação com a confirmação da procedência de um objeto ou de uma pessoa, ou seja, com a veracidade da sua identidade.

Para a área de segurança da informação, a autenticação é um método que consiste na verificação da identidade digital de um usuário de algum sistema, normalmente no momento de entrada ou de acesso ao sistema. O processo de autenticação envolve **fatores de autenticação**. Para ser autenticado em

um sistema, o usuário deve apresentar, durante o processo de *logon*, algum elemento que só ele possua ou só ele saiba; atualmente, podem ser exigidas inclusive características físicas individuais como forma de autenticação.

Sendo assim, os **recursos de autenticação** podem ser baseados nos seguintes princípios, conforme Teixeira Filho (2017):

- **O que o usuário sabe:** é um recurso de autenticação que exige do usuário um conhecimento específico. Nesse caso, é necessário que o usuário saiba previamente alguma informação, que será solicitada no momento do *logon*, como uma **senha**. Para ser autenticado, essa senha deverá ser informada corretamente, ou o acesso será negado. A vantagem da utilização desse tipo de recurso é a simplicidade, e a desvantagem é que outras pessoas podem descobrir a senha, realizar tentativas de acesso e ainda divulgá-la para outras pessoas.
- **O que o usuário tem:** esse é um recurso de autenticação que envolve a propriedade ou a titularidade de um objeto ou dispositivo, que normalmente vai gerar um **token temporário**, que será a chave para a autenticação do usuário. Nesse caso, se algum indivíduo mal-intencionado roubar a senha gerada, isso não acarretará problemas, uma vez que a senha expira em um curto intervalo de tempo. Esse tipo de recurso certamente é mais seguro do que o recurso da utilização do conhecimento do usuário.
- **O que o usuário é:** esse recurso de autenticação é ainda mais rigoroso e bem-sucedido, pois se baseia em uma característica própria do usuário que deseja se autenticar no sistema, comumente a **biometria**. Mesmo sendo muito seguro, os indivíduos mal-intencionados sempre conseguirão burlar a tecnologia de segurança de alguma forma, inclusive, nesse caso, fazendo moldes de silicone com as digitais do usuário verdadeiro.

Para evitar problemas com a segurança das informações, normalmente as organizações utilizam uma **combinação de recursos de autenticação** para efetivar o acesso de seus usuários. Um exemplo muito comum é a utilização de uma senha, que deve ser informada para que outra informação seja solicitada, como a digitação de um *token* ou a leitura da impressão digital.

Posteriormente ao processo de autenticação do usuário, vem o **processo de autorização**. Nesse processo, o usuário vai obter acesso somente aos recursos que tiverem sido liberados previamente pelo gestor do sistema, o que vai depender diretamente do **nível de acesso** que tiver sido designado a esse usuário. Uma vez que consiga ser autenticado para entrar em determinado sistema, o

usuário terá, então, acesso somente aos recursos específicos correspondentes ao seu tipo ou nível de acesso.



Fique atento

É preciso entender que autenticação não é sinônimo de autorização. A **autenticação** verifica a identidade de um usuário, e a **autorização** verifica se o usuário possui permissão para executar certas operações. Nesse sentido, a autenticação é algo que vem antes da autorização.

Além da autorização, ainda existe o **processo de auditoria**, que envolve a verificação contínua dos acessos concedidos aos usuários, verificando se estão corretos e se não há alterações que precisam ser feitas, pelo fato de algum usuário estar com acesso a recursos a mais ou a menos do que deveria, diante do seu perfil, da sua atividade ou da sua função na organização. A Figura 1 mostra a sequência de processos envolvidos no controle de acesso de usuários.

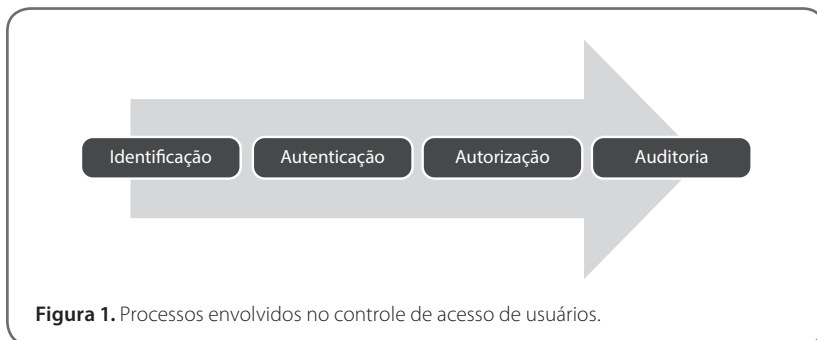


Figura 1. Processos envolvidos no controle de acesso de usuários.



Fique atento

A união de métodos consistentes de identificação, autenticação, autorização e auditoria vai proporcionar maior garantia de que o ambiente da rede terá um nível de segurança de informação adequado, evitando que a integridade dos dados e das informações seja afetada.

O controle de acesso

Segundo Tanenbaum e Wetherall (2011), na área da segurança da informação, a união dos processos ou serviços de identificação, autenticação, autorização e auditoria de usuários para entrada em um sistema forma um processo maior, chamado **processo de controle de acesso**. Quando o assunto é segurança física, o processo de controle de acesso conta com dispositivos que garantem o acesso a propriedades, prédios, salas e outros lugares apenas para pessoas que possuem autorização, ou porque desempenham alguma função que lhes dá esse direito, ou porque são clientes da área específica, ou ainda porque têm convite para frequentá-la, entre outros motivos. Esse controle pode ser feito por pessoas, como vigilantes e recepcionistas, ou ainda por meio de dispositivos, como fechaduras, chaves e alarmes.



Fique atento

- O processo de identificação envolve o ato de o usuário informar um identificador único para o sistema, durante o início do processo de *logon*.
- O processo de autenticação envolve o fato de o usuário provar para o sistema, durante o processo de *logon*, que ele é quem realmente diz ser, o que pode se dar por meio da inserção de uma senha, da leitura da impressão digital, etc.
- O processo de autorização acontece quando, depois de identificado e autenticado, o usuário consegue acessar somente aqueles recursos do sistema para os quais esteja liberado.
- O processo de auditoria consiste na coleta contínua de informações relacionadas à utilização dos recursos do sistema pelos usuários. A auditoria serve para que os profissionais de segurança da informação façam o planejamento, o gerenciamento, o controle e a responsabilização de usuários por uso indevido, bem como a verificação da adequação dos controles de acesso permitidos.

O processo de controle de acesso estabelece limites para os direitos de acesso dos usuários aos recursos do sistema, com o objetivo de permitir, para cada um, acesso somente ao que tiver sido previamente estipulado como permitido. Ele envolve o fato de **permitir ou negar acesso** à utilização de um objeto, que pode ser uma funcionalidade, um arquivo ou um sistema, por um sujeito, que pode ser um usuário, um processo ou até mesmo um outro sistema. A **restrição do acesso** pode não ser responsável pela eliminação completa dos riscos à segurança da informação dos sistemas, mas ela diminui

consideravelmente a incidência de problemas que podem comprometer a continuidade das atividades do negócio da empresa.

Conforme Nascimento (2014), o processo de controle de acesso pode ser classificado da seguinte forma:

Quanto à centralização do controle, como:

- **Centralizado:** esse é o tipo de controle de acesso em que um elemento-chave, que pode ser um sistema, ou ainda um usuário dotado de poderes para isso, vai tomar as decisões com relação aos acessos dos recursos. A vantagem desse tipo de controle é que ele assegura maior padronização para o acesso às informações, uma vez que a definição dos recursos normalmente é feita definindo-se grupos de perfis; para cada perfil, são liberados determinados acessos. Outra vantagem é que ele evita que os direitos de acesso se sobreponham, uma vez que cada usuário vai pertencer a um grupo específico. A desvantagem desse tipo de controle é que uma possível falha na leitura da definição dos acessos elaborada pelo elemento central impedirá qualquer acesso às informações, mesmo que temporário.
- **Descentralizado:** nesse tipo de controle de acesso, não existe a figura do elemento central, pois o controle é definido por elementos que ficam mais próximos de grupos de recursos, o que facilita o gerenciamento dos problemas. A grande vantagem desse tipo de controle é que a falha na leitura da definição de acessos de um grupo não vai interferir em todo o restante do sistema (ou sistemas), pois não há dependência entre os perfis. Em contrapartida, a desvantagem é que não existe uma padronização para os perfis de acesso, que são designados por pessoas diferentes, e pode haver sobreposição de direitos de acesso, o que significa falha na segurança.

Quanto ao controle feito pelo sistema, como:

- **Discrecionário:** nesse tipo de controle, a política de controle de acesso é definida pelo proprietário do recurso, que vai decidir quem terá permissão de acesso a determinado recurso e que tipo de privilégio terá. O controle de acesso discrecionário se baseia no fundamento de que toda funcionalidade ou objeto em um sistema, a menos que seja desprotegido, deve possuir um proprietário, e também que os privilégios, direitos de acesso e demais permissões podem ser dados pelo proprietário de cada

recurso, de maneira individual ou para grupos de usuários, divididos em perfis. O controle discricionário pode ser implementado por listas de controle de acesso, o que possibilita que um usuário pertença a um ou mais grupos, adquirindo permissões e privilégios cumulativos.

- **Obrigatório:** esse tipo de processo de controle de acesso pode ser chamado também de mandatário, uma vez que toda a política de concessão de acesso é determinada pelo sistema, e não por elementos ligados aos recursos. Esse tipo de controle é utilizado em sistemas cujos dados são extremamente sensíveis, como militares e de governo. É normal que seja definido um sistema que trabalhe com vários níveis de classificação entre os indivíduos, com respectivos níveis de privilégios ao acesso dos recursos, e também níveis de sensibilidade à informação. O **controle de acesso obrigatório** envolve dois elementos:
 - **Importação e exportação de dados:** o controle dos dados que são importados ou exportados para outros sistemas, ou até mesmo para impressoras, é de grande importância para o controle de acesso obrigatório. O sistema precisa assegurar que os níveis de sensibilidade serão mantidos e implementados corretamente, de maneira que a informação fique protegida o tempo todo.
 - **Níveis de sensibilidade:** em sistemas operados por esse tipo de controle, todos os sujeitos envolvidos e todos os objetos devem ter níveis de sensibilidade vinculados. Para o sujeito, eles definem o nível de confiança, e para um objeto, definem o nível de confiança que é preciso ter para acessá-lo. Para que possa acessar um objeto, o sujeito precisa ter o nível de sensibilidade exigido.

Após a definição desses aspectos, o sistema vai aplicar as regras de direito de acesso baseando-se nos privilégios de usuário e na sensibilidade indicada para as informações.

Quanto ao método de controle, baseado em:

- **Regras:** nesse tipo de controle, o acesso e os direitos são definidos por listas de regras elaboradas pelo administrador do sistema, que se fundamenta na rotulação da informação quanto à sua sensibilidade e no nível de privilégio que cada usuário deve ter. Esse tipo de controle normalmente se aplica ao controle de acesso mandatário ou obrigatório.
- **Perfis:** nesse tipo de controle, o acesso e os direitos a recursos são fundamentados em perfis, estabelecidos pela função, pelo cargo ou

pelo grupo ao qual pertence o usuário. Primeiramente, são definidos privilégios genéricos para os recursos do sistema; depois, os gestores dos recursos são responsáveis por determinar os privilégios para cada tipo de perfil de usuário, de forma discricionária. Esse tipo de controle normalmente se aplica ao controle de acesso discricionário.

O processo de controle de acesso foi idealizado para fornecer uma garantia de que o sistema foi projetado, implementado e testado de acordo com níveis de segurança específicos, conforme suas necessidades e especificidades, o que assegura aos usuários que trocam informações que ele forma um ambiente seguro, protegido de ataques de indivíduos mal-intencionados.

Os principais recursos de autenticação

Atualmente, os sistemas utilizam cartões inteligentes, *tokens*, impressão digital, reconhecimento de voz, formato da retina, entre outros meios de autenticação de usuário. No entanto, a **senha individual** continua sendo uma das maneiras mais comuns de autenticação. Para que uma política de autenticação por meio de senha funcione com sucesso, é preciso que os usuários recebam as seguintes orientações, conforme Teixeira Filho (2017):

- não divulguem nem compartilhem sua senha com terceiros;
- não anotem suas senhas em papel;
- alterem sua senha com frequência, ou sempre que houver desconfiança de que alguém possa ter conhecimento dela;
- não utilizem as mesmas senhas já utilizadas no mesmo sistema ou em outros sistemas, como os bancários;
- alterem a senha original informada pelo sistema assim que o primeiro processo de *logon* tenha sido efetuado com sucesso;
- escolham uma senha de fácil memorização, mas que seja difícil de ser adivinhada por outra pessoa;
- escolham senhas que possam ser digitadas rapidamente, dificultando que outras pessoas possam identificar os caracteres que forem digitados.

De maneira geral, os usuários devem evitar definir senhas com seu nome, sua identificação, nomes de familiares, letras ou números repetidos ou em sequência, datas, números de telefone, cartões de crédito, documentos como identidade e CPF e ainda marcas ou placas de veículos que possua. Isso se

deve ao fato de quem nem todos os sistemas estão preparados para identificar senhas que não são fortes e bloquear a escolha desse tipo de senha por parte dos usuários.

Em contrapartida, é essencial que a empresa mantenha arquivos criptografados com as senhas de seus usuários, que solicite a alteração da senha periodicamente e que ainda guarde as senhas anteriores dos usuários, evitando assim que eles alterem uma senha para alguma antiga que já tenham utilizado. Além disso, é importante que sejam revogadas as senhas de usuários aposentados, demitidos ou desligados por qualquer motivo, conforme afirmam Tanenbaum e Wetherall (2011).

Outro meio de autenticação de usuários é o **token**, que significa passe. Ele é um dispositivo físico que gera uma senha temporária de proteção para contas de sistemas que o usuário utilize. Como a senha ou código gerado pelo *token* é válido somente por um tempo determinado, isso dificulta a ação de indivíduos mal-intencionados. O *token* é um objeto que o usuário possui, que a partir de um comando vai gerar uma senha temporária para que ele se autentique em um sistema (Figura 2). Atualmente, o usuário pode utilizar o próprio *smartphone* para gerar o *token* que será utilizado para fazer sua autenticação.



Figura 2. Exemplos de *token*.

Fonte: Fonseca (2009).

Os **cartões inteligentes**, ou *smart cards*, possuem microprocessadores e capacidade de memória interna suficiente para conseguir armazenar dados, dificultando sua utilização por outras pessoas, que não sejam os seus titulares verdadeiros (Figura 3). O cartão inteligente armazena e processa as informações, o que dificulta a sua clonagem, já que pode oferecer recursos de criptografia. É comum que o usuário precise informar uma senha à leitora do cartão inteligente para que possa utilizá-lo; é uma medida a mais para evitar o seu roubo, conforme afirma Teixeira Filho (2017).



Figura 3. Exemplo de cartão inteligente, ou *smart card*.

Fonte: 2YouStockPhoto/Shutterstock.com.

Geralmente o recurso dos cartões inteligentes é utilizado por instituições bancárias devido à garantia da segurança da informação. Outras aplicações dos cartões inteligentes são na área da telefonia, para cartões de crédito e dinheiro eletrônico pré-pago, etc.

O **sistema de biometria** é outro recurso de autenticação que vem sendo cada vez mais aplicado. Ele é um sistema que verifica automaticamente a identidade do usuário, baseando-se nas suas características físicas. Seu objetivo é suprir vulnerabilidades dos demais meios de autenticação, que podem ser perdidos, roubados ou esquecidos. Via de regra, um sistema biométrico pode utilizar qualquer característica física do usuário como meio de autenticação, mas isso se limita ao fato de que a característica escolhida deve ser única, inclusive quando se lida com usuários que possuam irmã(o) gêmea(o). Entretanto, esse sistema não pode invadir a intimidade das pessoas.

Mesmo com toda a precisão envolvida na autenticação por sistemas de biometria, muitos erros podem acontecer, devido às mudanças de características físicas que ocorrem naturalmente com o passar dos anos, além de fatores como o nervosismo da pessoa que está se submetendo à autenticação ou os problemas de saúde. Esse tipo de sistema deve oferecer um certo nível de tolerância a erros, que não seja alto para admitir indivíduos maliciosos conseguindo autenticação, e nem baixo a ponto de negar acesso a usuários realmente autorizados. As características físicas preferencialmente utilizadas nos sistemas biométricos são: impressões digitais, reconhecimento de voz, geometria da mão, formato da retina ou da íris, reconhecimento facial, entre outros que já existem ou que venham a ser desenvolvidos.



Referências

BRASIL. Tribunal de Contas da União. *Boas práticas em segurança da informação*. 4. ed. Brasília: TCU, 2012.

FONSECA, W. *O que é token?* 2009. Disponível em: <<https://www.tecmundo.com.br/senha/3077-o-que-e-token-htm>>. Acesso em: 12 jun. 2018.

NASCIMENTO, H. B. *Segurança da informação para concursos*. Rio de Janeiro: Ciência Moderna, 2014.

TANENBAUM, A. S.; WETHERALL, D. J. *Redes de computadores*. São Paulo: Pearson, 2011.

TEIXEIRA FILHO, S. A. *Segurança da informação descomplicada*. São Paulo: Cultura, 2017.

Encerra aqui o trecho do livro disponibilizado para esta Unidade de Aprendizagem. Na Biblioteca Virtual da Instituição, você encontra a obra na íntegra.

Conteúdo:



SOLUÇÕES
EDUCACIONAIS
INTEGRADAS